CRA-related standards

Status from 6 January

OpenSSF

OPEN SOURCE SECURITY FOUNDATION

Copyright © 2024 The Linux Foundation®. All rights reserved. The Linux Foundation has registered trademarks and uses trademarks.

Happy, healthy and prosperous New Year

Agenda

- Public inquiry phase for CRA-related standards
- Events
- Questions about CRA
- AOB
- Back-up slides

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Public inquiry phase for CRA-related standards

CRA Work Items

CRA	M/606 ID	Venue	Work Item	Standard reference	Standard title
		CEN-CLC/JTC 13 WG 9	JT013095	EN 40000-1-1	Cybersecurity requirements for products with digital elements – Vocabulary
I.I	2 to 14	CEN-CLC/JTC 13 WG 9 PT1	JT013089	EN 40000-1-2:2025	Cybersecurity requirements for products with digital elements – Principles for cyber resilience
I.II	2 to 14	CEN-CLC/JTC 13 WG 9 PT3	JT013090	EN 40000-1-3	Cybersecurity requirements for products with digital elements – Vulnerability Handling
	2 to 14	CEN-CLC/JTC 13 WG 9 PT2	JT013091	EN 40000-1-4	Cybersecurity requirements for products with digital elements – Generic Security Requirements
	2 to 14	CEN-CLC/JTC 13 WG 9	JT013097	TR 40000-1-5	Cybersecurity requirements for products with digital elements – Threats and Security Objectives
	2 to 14	CEN-CLC/JTC 13 WG 6	JT0130XX	TS TTTTTTT	Guidance for the application of EN 18037 in support of the CRA
	2 to 14	CEN-CLC/JTC 13 WG 6	JT0130XX	TR TTTTTT	Documentation of the EN 18037 assessment results for the Consumer IoT market sector
III.I.1	16	CEN/TC 224 WG 17		EN TTTTTTT	Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers : criteria to fulfill with the essential requirements from regulation 2024/2487 (CRA)
III.I.2	17	ETSI CYBER-EUSR	DEN/CYBER-EUS-006	EN 304 617	Essential cybersecurity requirements for browsers
III.I.3	18	ETSI CYBER-EUSR	DEN/CYBER-EUS-007	EN 304 618	Essential cybersecurity requirements for password managers
III.I.4	19	ETSI CYBER-EUSR	DEN/CYBER-EUS-0018	EN 304 619	Essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software
III.I.5	20a	ETSI CYBER-EUSR	DEN/CYBER-EUS-005	EN 304 620	Essential cybersecurity requirements for virtual private networks (VPNs)
III.I.5	20b	CLC/TC 65X WG 3	81652	EN 62443-5-XX	Security Profile for products with digital elements with the function of virtual private network (VPN)
III.I.5+6+7	20b+21b+22b	CLC/TC 65X WG 3	79830	EN IEC 62443-3-3:2019	Industrial communication networks - Network and system security - Part 3-3: System security requirements and security levels
III.I.5+6+7	20b+21b+22b	CLC/TC 65X WG 3	81487	EN IEC 62443-4-1:2018	Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements
III.I.5+6+7	20b+21b+22b	CLC/TC 65X WG 3	79973	EN IEC 62443-4-2:2019	Security for industrial automation and control systems - Part 4-2: Technical security requirements for IACS components
III.I.6	21a	ETSI CYBER-EUSR	DEN/CYBER-EUS-009	EN 304 621	Essential cybersecurity requirements for network management systems
III.I.6	21b	CLC/TC 65X WG 3	81650	EN 62443-5-XX	Security Profile for network management systems (based on IEC 62443)
III.I.7	22a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0010	EN 304 622	Essential cybersecurity requirements for Security information and event management (SIEM) systems
III.I.7	22b	CLC/TC 65X WG 3	81654	EN 62443-5-XX	Security Profile for security information and event management (SIEM) systems (based on IEC 62443)
III.I.8	23	ETSI CYBER-EUSR	DEN/CYBER-EUS-008	EN 304 623	Essential cybersecurity requirements for boot managers

CRA Work Items

CRA	M/606 ID	Venue	Work Item	Standard reference	Standard title
III.I.9	24	ETSI CYBER-EUSR	DEN/CYBER-EUS-0015	EN 304 624	Essential cybersecurity requirements for public key infrastructure and digital certificate issuance software
III.I.10	25a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0017	EN 304 625	Essential cybersecurity requirements for physical and virtual network interfaces
III.I.10	25b	CLC/TC 65X WG 3	81651	EN 62443-5	Security Profile for physical and virtual network interfaces (based on IEC 62443)
III.I.11	26	ETSI CYBER-EUSR	DEN/CYBER-EUS-0012	EN 304 626	Essential cybersecurity requirements for operating systems
III.I.12	27a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0013	EN 304 627	Essential cybersecurity requirements for routers, modems intended for the connection to the internet, and switches
III.I.12	27b	CLC/TC 65X WG 3	81653	EN 62443-5	Security Profile for routers, modems intended for the connection to the internet, and switches (based on IEC 62443)
III.I.13+14	28, 29	CLC/TC 47X WG 1	80923	EN 50765	Essential cybersecurity requirements for microprocessors and microcontrollers with security-related functionalities
III.I.15	30	CLC/TC 47X/WG CRA		EN 50767	Essential cybersecurity requirements for application specific integrated circuits (ASIC) and field-programmable gate arrays (FPGA) with security-related functionalities
III.I.16	31	ETSI CYBER-EUSR	DEN/CYBER-EUS-0011	EN 304 631	Essential cybersecurity requirements for smart home general purpose virtual assistants
III.I.17	32	ETSI CYBER-EUSR	DEN/CYBER-EUS-0014	EN 304 632	Essential cybersecurity requirements for smart home products with security functionalities, including smart door locks, security cameras, baby monitoring systems and alarm systems
III.I.18	33	ETSI CYBER-EUSR	DEN/CYBER-EUS-004	EN 304 633	Essential cybersecurity requirements for Internet connected toys covered by Directive 2009/48/EC that have social interactive features (e.g. speaking or filming) or that have location tracking features
III.I.19	34	ETSI CYBER-EUSR	DEN/CYBER-EUS-003	EN 304 634	Essential cybersecurity requirements for personal wearable products to be worn or placed on a human body that have a health monitoring (such as tracking) purpose and to which Regulation (EU) 2017/745 or Regulation (EU) 2017/746 do not apply or personal wearable products that are intended for the use by and for children
III.II.1	35	ETSI CYBER-EUSR	DEN/CYBER-EUS-0016	EN 304 635	Essential cybersecurity requirements for hypervisors and container runtime systems that support virtualised execution of operating systems and similar environments
III.II.2	36a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0020	EN 304 636	Essential cybersecurity requirements for firewalls, intrusion detection and/or prevention systems
III.II.2	36b	CLC/TC 65X WG 3	81649	EN 62443-5	Security Profile for firewalls and intrusion detection and prevention systems (based on IEC 62443)
III.II.3+4	37, 38	CLC/TC 47X WG 2	80924	EN 50766	Cybersecurity requirements for tamper-resistant microprocessors and microcontrollers
IV.1	39	CEN/TC 224 WG 17	002242XX	EN TTTTT	Cybersecurity requirements for Hardware Devices with Security Boxes
IV.2	40	CEN-CLC/JTC 13 WG 6	JT0130XX	EN TTTTT	Cybersecurity requirements for products with digital elements – Smart Meter Gateway
IV.3	41a	CLC/TC 47X WG 3	80922	EN 50764	Cyber Resilience of EUCC certified platforms of Smart Cards and Similar Devices Including Secure Elements
IV.3	41b	CEN/TC 224 WG 17		EN TTTTTT	Smartcards, similar devices and Secure Elements – criteria to achieve conformity with essential requirements of Regulation (EU) 2024/2847.
		ETSI CYBER-EUSR	DEN/CYBER-EUS-0019	EN 304 642	Cybersecurity Requirements for Network Functions of Telecommunications Systems

CEN Public Inquiry

- PT1 and Vocabulary have ended their public inquiry phase
  - They enter in the comments resolution phase starting 12 January
  - This phase is targeted to close no later than 26 April
  - Three meetings per week
- PT2
  - Has resumed its activities on 2 December
  - They will publish a supporting TR "Cybersecurity requirements for products with digital elements – Threats and Security Objectives" very soon
  - It's the only horizontal that will be delivered in 2027
  - Drafting will continue for two months
  - Comments resolution will last another two months
  - Public Inquiry phase is planned for 3 months in May-July 2026
- PT3
  - CEN sent PT3 (40000-1-3) to the NSBs to initiate the ENQ phase last week
    - It takes a few days to have that available on their website
    - On NBN website already available (ENQ will run until 9 Feb)
    - DIN plans to have the ENQ phase between 9 Jan and 9 March
  - Still not clear if it will get the presumption of conformity
  - Expected to be published in October 2026

	Oct-25	Nov-25	Dec-25	Jan-26	Feb-26	Mar-26	Apr-26	May-26	Jun-26	Jul-26
Vocabulary 40000-1-1										
PT1 40000-1-2										
PT2 40000-1-4										
PT3 40000-1-3										

Extract from OpenSSF feedback for PT1 and vocabulary

Item number	Type of comment (editorial, technical, remark)	Comments	Proposed change
5.4.2 Guidance	technical	We would like to expand this phrase "This is done by minimizing the attack surface of a product, ensuring that secure configurations are the default, and informing the users about the default secure state."	This is done by implementing tactics like: eliminating the default passwords implementing Multi-Factor Authentication use Single Sign-On mechanisms based on open standards providing secure logging without further additional configuration Creating Software Authorization Profiles and their designated use cases Tracking and reducing 'hardening guide' size Prioritizing the security over backwards compatibility. Source "https://www.cisa.gov/sites/default/files/2023-10/SecureByDesign_1025_508c.pdf"
5.5.2 Guidance	technical	In the list started after "Transparency includes amongst others, methods of relaying information related to:"	we would like to add another topic in that list "- third-party software components used"
6.1 General	editorial	update "reviewing management of the risks according"	include monitoring also in this. The last bullet should be "monitoring and reviewing management of the risks according to 6.7" that will provide also an alignment with the figure from below
6.1 General	technical	update figure 1 and the phases of risk assessment	we would like to add also add risk identification in the risk assessment phase
6.2.1.2 Product intended purpose and reasonable foreseeable use	editorial	some gramatical errors and unclarity in the "Intended purpose: to controls physical access to residential and office premises via a smartphone application and digital key management. Reasonably foreseeable use:"	replace with: "Its intended purpose is to control physical access to residential and office premises via a smartphone application and digital key management. Its Reasonably foreseeable use can be described through the next actions:"
6.2.1.6 Product user description	editorial	The phrase "The product's end user, also referred to in this document as user, is any natural or legal person intended to install/operate/handle/use." is missing a pronoun or a noun	add 'the product' or 'it' at the end of the phrase
6.2.1.6 Product user description	technical	referring to the "install/operate/handle/use" phases from this chapter	add update/upgrade?
6.2.2 Input	editorial	why 'existing' in "existing product architecture"? we would propose to remove it	remove the term 'existing'
6.2.3 Requirement	technical	regarding the phrase "It is recommended to align with the terminology used in the blue guide to describe the product user."	We would remove that line from this section and detail it in 6.2.1.6.
6.3.1 General	technical	regarding the phrase "whether appropriate risk treatment has been applied, and whether the residual risk is acceptable or further mitigation is required." How can this be true in the step number 2 of this process? should not be the risk identified prior to establishing such things?	please justify that step in this phase

Annex B
(informative)

Example of a Cybersecurity Supplier Agreement (CSSA)

B.1 General

Products with digital elements often integrate third-party components and services — including commercial, free, or open-source components — which can introduce cybersecurity risks due to limited control over their lifecycle, design, and support. Managing these risks requires clear responsibilities and structured collaboration between manufacturers and third-party providers.

This annex provides an example of a Cybersecurity Supplier Agreement (CSSA) between the manufacturer and third-party providers (suppliers) of components or services, mainly applicable in a business-to-business context.

To ensure proper cybersecurity and clear responsibilities along the whole supply chain, each entity can initiate a CSSA with its suppliers, as shown in Figure B.1.

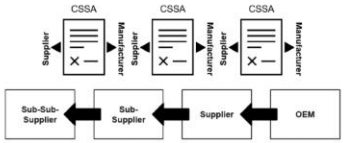


Figure B.1 — Example of CSSAs in the supply chain

A CSSA can support compliance with the requirements of 7.11 by enabling both parties to align on distributed cybersecurity activities and responsibilities during the selection, integration, risk assessment, and maintenance of third-party components, thereby supporting a due diligence approach.

A CSSA can help ensure that risks are addressed at the appropriate location in the supply chain via a shared risk model. This is because some risks are easier to address either upstream or downstream in the supply chain.

The CSSA example is intended to:

— clarify responsibilities in managing cybersecurity activities associated with third-party components;

— align on key assumptions and their validation;

— support alignment on integration instructions, vulnerability handling, and incident response;

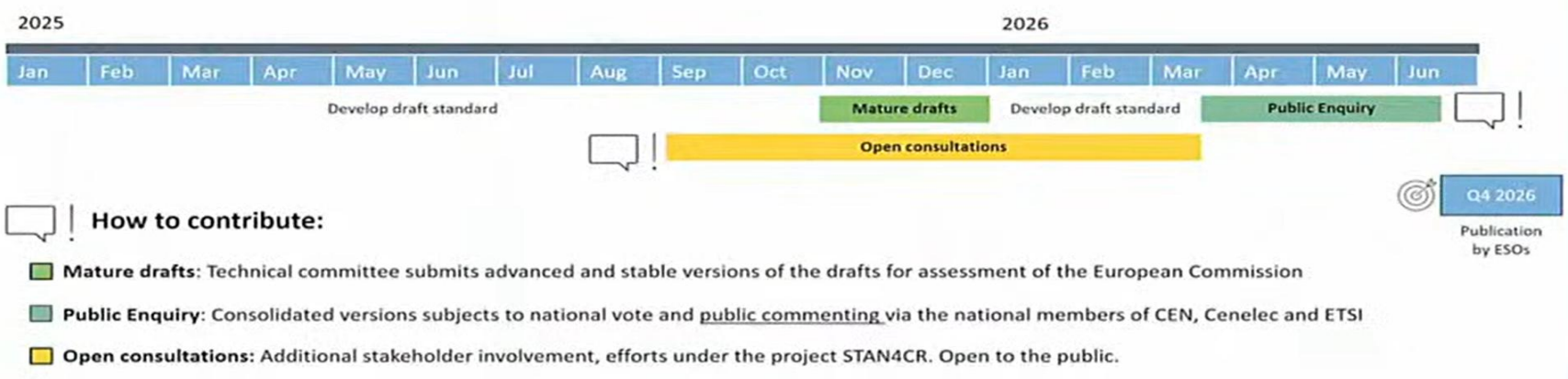
— define required documentation, risk management, lifecycle monitoring expectations, and support periods;

— serve as a basis for auditability and verification of cybersecurity due diligence.

Depending on the product context, the CSSA may include further details such as point of contact, responsibilities at each stage, information exchange formats, methods or tools for collaboration, and

ETSI Open/Public Consultation

- Previewed by a webinar on 29 September
- First phase has ended on 30 November
  - After this phase, ETSI reviewed and assessed the feedback received and implemented all the necessary updates.
- A second phase ended on 31 December
  - They will repeat the same things as for the previous month
- A third one started in January
- Instructions for submitting feedback can be found in the readme.md files available with every standard.
  There are two official submission options:
  - Directly in the .md file or related to the .pdf files from the labs.etsi.org repositories.
  - Via an Excel template available on docbox.etsi.org.
- My strong suggestion is to submit your feedback using one of the two official ETSI options listed above.
- If you submitted feedback, please check the newest drafts to see if your comments have been taken into account
- Some of the vertical standards have been sent for HAS assessment



ETSI upcoming deep-dive sessions

These sessions will focus on the following topics:

- PKI and Digital Certificate Issuance Software
  - On January 14, between 2 and 3:30 PM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84012
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions
- VPNs
  - On January 14, between 3:30 PM and 5 PM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84013
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions
- Password Managers
  - On January 15, between 2 and 3:30 PM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84014
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions
- Boot Managers
  - On January 15, between 3:30 PM and 5 PM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84015
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions
- Network Management Systems
  - On January 21, between 2 and 3:30 PM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84016
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions
- Physical and Virtual Network Interfaces
  - On January 21, between 3:30 PM and 5 PM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84017
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions
- Browsers
  - On January 22, between 3:30 PM and 5 PM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84018
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions
- Operating Systems
  - On January 23, between 10 AM and 11:30 AM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84019
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions
- SIEM Systems
  - On January 23, between 11:30 AM and 1 PM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84020
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions
- Consumer IoT
  - On February 6, between 2PM and 5PM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84021
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions

CYBER E…	New	CYBEREUSR-CRA Consumer IoT Verticals#18	2026-01-13	2026-01-13	Online	(7)	(1)	
CYBER E…	New	CYBEREUSR-CRA Standard Unlocked - deep dive se…	2026-01-14	2026-01-14	Online	(10)	(0)	
CYBER E…	New	CYBEREUSR-CRA Standard Unlocked - deep dive se…	2026-01-14	2026-01-14	Online	(4)	(0)	
CYBER E…	New	CYBEREUSR-CRA Standard Unlocked - deep dive se…	2026-01-15	2026-01-15	Online	(2)	(0)	
CYBER E…	New	CYBEREUSR-CRA Standard Unlocked - deep dive se…	2026-01-15	2026-01-15	Online	(5)	(0)	
CYBER E…	New	CYBEREUSR-CRA Standard Unlocked - deep dive se…	2026-01-21	2026-01-21	Online	(5)	(0)	
CYBER E…	New	CYBEREUSR-CRA Standard Unlocked - deep dive se…	2026-01-21	2026-01-21	Online	(5)	(0)	
CYBER E…	New	CYBEREUSR-CRA Standard Unlocked - deep dive se…	2026-01-22	2026-01-22	Online	(1)	(0)	
CYBER E…	New	CYBEREUSR-CRA Standard Unlocked - deep dive se…	2026-01-23	2026-01-23	Online	(4)	(0)	
CYBER E…	New	CYBEREUSR-CRA Standard Unlocked - deep dive se…	2026-01-23	2026-01-23	Online	(1)	(0)	

As before, these sessions are open to the general public and are designed to provide detailed insight into the ongoing work by ETSI rapporteurs.
They also offer an excellent opportunity for participants to explore draft standards and share feedback.

Standards complexity

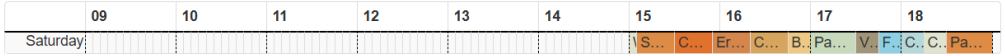
Ident	Version	Work Item	Product	Pages	Shalls	Shall/Page
40000-1-1		JT013095	vocabulary	7	0	
40000-1-2		JT013089	cyber resilience	59	118	2.0
40000-1-3		JT013090	vulnerability	51	80	1.6
40000-1-4		JT013091	generic	83	49	0.6
40000-1-5		JT013097	threats	14	0	
EN 304 617	0.0.8	DEN/CYBER-EUS-006	browser	434	957	2.2
EN 304 618	0.0.5	DEN/CYBER-EUS-007	password mgr	120	131	1.1
EN 304 619	0.0.12	DEN/CYBER-EUS-0018	antivirus	140	146	1.0
EN 304 620	0.0.14	DEN/CYBER-EUS-005	VPN	45	58	1.3
EN 304 621	0.0.6	DEN/CYBER-EUS-009	net mgr	56	57	1.0
EN 304 622	0.0.4	DEN/CYBER-EUS-0010	SIEM	37	38	1.0
EN 304 623	0.0.11	DEN/CYBER-EUS-008	boot mgr	87	116	1.3
EN 304 624	0.0.6	DEN/CYBER-EUS-0015	PKI	67	140	2.1
EN 304 625	0.0.11	DEN/CYBER-EUS-0017	net interfaces	73	90	1.2
EN 304 626	0.0.10	DEN/CYBER-EUS-0012	OS	79	99	1.3
EN 304 627	0.0.11	DEN/CYBER-EUS-0013	routers	108	137	1.3
EN 304 631	0.1.0	DEN/CYBER-EUS-0011	virtual assist	53	197	3.7
EN 304 632	0.1.0	DEN/CYBER-EUS-0014	smart home	53	197	3.7
EN 304 633	0.1.0	DEN/CYBER-EUS-004	toys	53	200	3.8
EN 304 634	0.1.0	DEN/CYBER-EUS-003	wearable	37	42	1.1
EN 304 635	0.0.10	DEN/CYBER-EUS-0016	virtualisation	129	397	3.1
EN 304 636	0.0.7	DEN/CYBER-EUS-0020	firewall	103	127	1.2
EN 304 642	0.0.6	DEN/CYBER-EUS-0019	telecom net	58	22	0.4

Events

FOSDEM 2026

CRA in practice

Room: UA2.114 (Baudoux)
Calendar: iCal, xCal
Chat: Join the conversation!



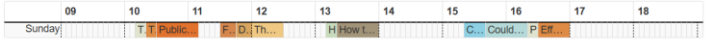
Read the Call for Papers at https://lists.fosdem.org/pipermail/fosdem/2025q4/003697.html.

Event	Speakers	Start	End
Saturday			
Welcome to the Devroom	Roman Zhukov	15:00	15:05
Software Supply Chain Strategy at Deutsche Bahn	Max Mehl, Henry Sachs	15:05	15:30
CRA-by-Design: Protocol-Embedded Compliance for EV Charging Infrastructure	Achim Friedland	15:30	15:55
Erlang/OTP's journey toward CRA compliance	Kiko Fernandez-Reyes	15:55	16:20
CRA Compliance in Embedded Systems: A Practical Look from the Yocto Project World	Marta Rybczynska	16:20	16:45
Building CRA-Ready Open Source Communities: The Critical Role of Community Managers	Cynthia Lo, Cassie Jiun seo	16:45	17:00
Panel: From Minimum Compliance to Meaningful Stewardship	Madalin Neag	17:00	17:30
VEX - Cutting through the Noise in Software Supply Chain Security	Rao Lakkakula, Georg Kunz	17:30	17:45
First steps towards CRA conformity. A practical introduction to cybersecurity risk management.	Harald Fischer	17:45	18:00
Can security attestations deliver on their promise to simplify due diligence and strengthen open source sustainability?	Tobie Langel	18:00	18:15
CRA-ppy data: We need better open data for CRA compliance	Georg Link, Thomas Steenbergen	18:15	18:30
Panel: Why is the CRA worth a FOSS maintainer's attention?	Roman Zhukov, Philippe Ombredanne	18:30	19:00

OpenSSF's Stand location: K2-A-03-Linux Foundation Europe + Open Source Security Foundation (next to CNCF + OpenInfra stand)

Open Source & EU Policy

Room: UA2.118 (Henriot)
Calendar: iCal, xCal
Chat: Join the conversation!



Read the Call for Papers at https://softwarefreedom.net/fosdem-2026-cfp.

Event	Speakers	Start	End
Sunday			
The Euroshack	André Rebentisch	10:10	10:20
The Missing Level: Why EU Open Source Fails Locally	Rasmus Frey	10:20	10:30
Public Procurement for Digital Sovereignty	Sebastian Raible	10:30	11:10
From policy to practice: implementing the EU AI Act for open-source software	Daphne Muller	11:30	11:45
Digital Omnibus: is the EU's tech simplification a Risk or Opportunity for Open Source?	Denise R. S. Almeida	11:45	12:00
The Fediverse and the EU's Digital Services Act: solving the challenges of modern social media?	Jordan Maris	12:00	12:30
HowTheyVote.eu - how we make European Parliament roll-call votes more accessible	Linus Hagemann, Till Prochaska	13:10	13:20
How to engage with policymakers as civil society	Jordan Maris, Sebastian Raible	13:20	14:00
Could Compliance Costs Sustain FOSS? A Theory of Voluntary Attestations	Æva Black	15:20	15:40
Could Compliance Costs Sustain FOSS? A Panel With The Public Sector	Æva Black, Michael Schuster, Greg Wallace, Tommaso Bernabo'	15:40	16:20
Participating in Standardisation around the CRA	Simon Phipps, Jordan Maris	16:20	16:30
Effective standard-setting	Tobie Langel	16:30	17:00

SBOMS and supply chains

Room: UD2.208 (Decroly)
Calendar: iCal, xCal
Chat: Join the conversation!

Read the Call for Papers at https://lists.fosdem.org/pipermail/fosdem/2025q4/003702.html.

Event	Speakers	Start	End
Sunday			
Welcome to the SBOMs and Supply Chains devroom!	Alexios Zavras (zvr), Kate Stewart, Adolfo García Veytia, Thomas Steenbergen	09:00	09:10
The day in a life of a SBOM	Anthony Harrison	09:10	09:30
When One Product Has Three SBOMs: Lessons from Embedded Vulnerability Management	Marta Rybczynska	09:30	10:00
Contextual SBOMs and impact on vulnerability management	Erik Mravec, Martin Jediný	10:00	10:30
Beyond SBOM: Integrating VEX into Open Source Workflows	Piotr P. Karwasz	10:30	11:00
From Passive Data to Active Defense: Supply Chain Policy-as-Code with Conforma	Stefano Pentassuglia	11:00	11:30
CRA-Ready SBOMs: A Practical Blueprint for High-Quality Generation	Viktor Petersson	11:30	12:00
Deutsche Bahn's Approach to Large-Scale SBOM Collection and Use	Max Mehl, Henry Sachs	12:00	12:20
LibreOffice and Collabora Online - how we managed to automate SBOM generation for a large legacy project	Thorsten Behrens	12:40	13:00
Forget SBOMs, use PURLs	Philippe Ombredanne, Steve Springett	13:20	13:40
What is new in SPDX 3.1 which is now a Living Knowledge Graph	Karen Bennet	14:00	14:30
A semantic framework for modelling and analysing supply chains through SBOMs	Giacomo Tenaglia	14:30	15:00
C/C++ Build-time SBOMs with pkgconf	Arianne Conill	15:30	16:00
Enhancing Swift's Supply Chain Security: Build-time SBOM Generation in Swift Package Manager	Ev Cheng, Sam Khouri	16:00	16:30
Generating SBoMs for BuildStream projects	Abderrahim Kitouni	16:30	17:00

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

https://fosdem.org/2026/schedule/track/open-source-eu-policy/
https://fosdem.org/2026/schedule/track/cra-in-practice/
https://fosdem.org/2026/schedule/track/sboms-and-supply-chains/

CRAzy About Product Cybersecurity

- Held on 3rd December between 10:00 and 12:00 CET
- Hosted by EC (CRA team)
- What was presented:
  - The CRA explained: objectives, scope, and practical implications
  - Cooperation across institutions, industry and Member States: who does what
  - Turning CRA into reality: key phases of the implementation phase, guidance, and ongoing regulatory efforts
  - Making the CRA fit for SMEs: actions to support compliance of smaller businesses
  - From compliance to innovation: state of the play of the standardisation work supporting the CRA
- Further details, including the link to join the session, are available here: CRAzy About Product Cybersecurity: From Compliance to Confidence
- Recording available here

CEN-CENELEC webinars on Hardware devices with security boxes

- CRA Standards Unlocked: Cybersecurity Requirements for Hardware Devices with Security Boxes
  - Online — 08 January 2026 | 11:00–12:30 CET
  - Kick off the year with an essential look at the harmonized standard for Hardware Devices with Security Boxes. Join experts from CEN TC 224 WG 17 as they explain the latest developments and how this work will help you meet the CRA's cybersecurity requirements in a pragmatic, standards-aligned way.
  - Register now for this session and get ahead in your CRA planning!

- CRA Standards Unlocked: Deep Dive Session on Cybersecurity Requirements for Hardware Devices with Security Boxes
  - Online — 22 January 2026 | 13:00–17:00 CET
  - Take a deeper dive into the draft standard with the project's rapporteur and technical experts. This extended session offers hands-on insights into the design approach, compliance criteria shaping, and discussion opportunities that go beyond the high-level overview.
  - Secure your seat — this interactive session is perfect for technical leads, product security teams, SMEs and standards stakeholders.

Complementary CRA implementation steps

CRA website

How it works

Manufacturers

Learn more on new rules for suppliers of hardware products and software developers subject to the CRA

Member States

Learn more about market surveillance and the role of Member States

Small and medium-sized enterprises (SMEs)

Learn more about funding and tools available to support SMEs and start-ups

Open-source community

Learn more about the role of the open-source community for the implementation of the CRA

28 November 2025	Implementing act on technical descriptions related to important and critical products
11 December 2025	Delegated act on CSIRTs withholding notifications to be disseminated through the Single Reporting Platform (adopted, publication pending objection period)
Early 2026	First set of Commission guidance on the Cyber Resilience Act implementation
11 June 2026	Entry into application of the provisions on the notification of Conformity Assessment Bodies. Member States to designate notifying authorities
Q3 2026	First standardisation deliverables (horizontal and product-specific standards)
11 September 2026	Entry into application of reporting obligations
11 December 2026	Notification of sufficient Conformity Assessment Bodies across Member States
30 October 2027	More standardisation deliverables
11 December 2027	Full application of the Cyber Resilience Act

CRA EG Guidelines

Article 26

Guidance

1. In order to facilitate implementation and ensure the consistency of such implementation, the Commission shall publish guidance to assist economic operators in applying this Regulation, with a particular focus on facilitating compliance by microenterprises and small and medium-sized enterprises.

2. Where it intends to provide guidance as referred to in paragraph 1, the Commission shall address at least the following aspects:

(a) the scope of this Regulation, with a particular focus on remote data processing solutions and free and open-source software;

(b) the application of support periods in relation to particular categories of products with digital elements;

(c) guidance targeted at manufacturers subject to this Regulation that are also subject to Union harmonisation legislation other than this Regulation or to other related Union legal acts;

(d) the concept of substantial modification.

The Commission shall also maintain an easy-to-access list of the delegated and implementing acts adopted pursuant to this Regulation.

3. When preparing the guidance pursuant to this Article, the Commission shall consult relevant stakeholders.

FAQ

Scope of the regulation

- When is a product in the scope of the CRA?
- What is a PDE?
- What does it mean to place a product on the market?
- Is source code a PDE?
- Does CRA applies to products placed on the market before CRA?
- Are products that are used only internally, in scope of the CRA?

Interplay with other legislations

- PLD
- RED DA
- AI Act
- GDPR
- Data Act
- Machine Regulation

Important and critical products

Manufacturer's obligations

- Risk-based approach and risk-assessment
- Vulnerability handling requirements
- Essential requirements (Annex I, part II)
- Due diligence requirements
- Support period

Reporting obligations

Substantial modification

Conformity assessment

Transition period

RDPS

Notion of 'at a distance'

'function'

Outsourced solutions

Overlap with NIS2?

Risk Assessment

CRA requirements

intended purpose, reasonably foreseeable use and reasonably foreseeable misuse

Length of time the product is expected to be in use

hEN and risk assessment

Open Source

Monetization

Stewards

New flow-chart (manufacturer vs steward)

Contributors and downstream uses

Sharing fixes upstream

Examples of scenarios

FAQs on the Cyber Resilience Act

The Cyber Resilience Act (Regulation (EU) 2024/2847) lays down rules for the making available on the market of products with digital elements to ensure their cybersecurity, essential cybersecurity requirements for the design, development and production as well as vulnerability handling processes, obligations for economic operators in relation to those products, and rules on market surveillance and enforcement.

This preliminary set of technical Frequently Asked Questions (FAQs), published approximately two years before the entry into application of the Cyber Resilience Act (CRA), is designed to assist stakeholders in the implementation of the CRA. The FAQs are not meant to cover exhaustively the scope of the CRA, but rather aim to address recurring questions that the Commission services have collected since the entry into force of the CRA. This is intended to be a 'living document' that will be updated as and when necessary.

This document is prepared by the Commission services and should not be considered as representative of the European Commission's official position. The replies to the FAQs do not extend in any way the rights and obligations deriving from applicable legislation nor introduce any additional requirement. The expressed views are not authoritative and cannot prejudge any future actions the European Commission may take, including potential positions before the Court of Justice of the European Union, which is competent to authoritatively interpret Union law.

The Commission is also working on guidance pursuant to Article 26 of the CRA, to be adopted in the coming months.

FAQ Version	Date	Changes
1.0	03/12/2025	New

https://digital-strategy.ec.europa.eu/en/factpages/cyber-resilience-act-implementation
https://ec.europa.eu/newsroom/dae/redirection/document/122331

Conformity assessment

Certification type	Product categories: 1 Default (90% of products)	2 Important Class I	3 Important Class II	4 Critical
EU Declaration of Conformity (self-assessment)	Printers, Bluetooth speakers, games, mobile apps			
Conformity assessment based on internal control following harmonized standards (self-assessment)		Routers, switches, access controls, browsers, VPN, ASIC FPGA, password managers, wearables		
Needs Third-party assessment			Hyper visors, firewalls, tamper-resistant micro-processors, and micro-controllers	
Compliance to certification ENISA schemes, such as the EUCC, at a minimum 'substantial' level				Hardware devices with security boxes, smart meter gateways, smart cards or similiar devices, including secure elements

In accordance with Article 32(5), manufacturers retain the possibility to use module A even in the case of an important product with digital elements of class I or II if their product qualifies as free and open-source software and the technical documentation is made available to the public.

Module A

- Set out in part I of Annex VIII
- A conformity assessment procedure in which the manufacturer verifies that the product with digital elements complies with the essential requirements of the CRA and declares compliance on its sole responsibility.

Module B+C

- set out in Parts II and III of Annex VIII
- A conformity assessment procedure in which the manufacturer verifies that the product with digital elements complies with the essential requirements of the CRA, a notified body examines the design and development of the product, and the manufacturer declares compliance.

Module H

- set out in Part IV of Annex VIII
- A conformity assessment procedure in which the manufacturer implements a full quality control system that ensures that the products subject to this system comply with the essential requirements of the CRA in both the design and the production phases.
- A notified body assesses the overall performance of the quality control system, including periodical tests and checks.

https://www.sgs.com/en/news/2025/03/cc-2025-q1-why-the-cyber-resilience-act-matters

Implementing regulation (EU) 2025/2392

Technical description of the categories of important and critical products with digital elements – link

IMPORTANT PRODUCTS WITH DIGITAL ELEMENTS – Class II
Hypervisors and container runtime systems that support virtualized execution of operating systems and similar environments
Firewalls, intrusion detection and prevention systems
Tamper-resistant microprocessors
Tamper-resistant microcontrollers

CRITICAL PRODUCTS WITH DIGITAL ELEMENTS
Hardware Devices with Security Boxes
Smart meter gateways within smart metering systems as defined in Article 2(23) of Directive (EU) 2019/944 of the European Parliament and of the Council (1) and other devices for advanced security purposes, including for secure cryptoprocessing
Smartcards or similar devices, including secure elements

IMPORTANT PRODUCTS WITH DIGITAL ELEMENTS – Class I
Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers
Standalone and embedded browsers
Password managers
Software that searches for, removes, or quarantines malicious software
Products with digital elements with the function of virtual private network (VPN)
Network management systems
Security information and event management (SIEM) systems
Boot managers
Public key infrastructure and digital certificate issuance software
Physical and virtual network interfaces
Operating systems
Routers, modems intended for the connection to the internet, and switches
Microprocessors with security-related functionalities
Microcontrollers with security-related functionalities
Application specific integrated circuits (ASIC) and field-programmable gate arrays (FPGA) with security-related functionalities
Smart home general purpose virtual assistants
Smart home products with security functionalities, including smart door locks, security cameras, baby monitoring systems and alarm systems
Internet connected toys covered by Directive 2009/48/EC of the European Parliament and of the Council (1) that have social interactive features (e.g. speaking or filming) or that have location tracking features
Personal wearable products to be worn or placed on a human body that have a health monitoring (such as tracking) purpose and to which Regulation (EU) 2017/745 (2) or (EU) 2017/746 of the European Parliament and of the Council (3) do not apply, or personal wearable products that are intended for the use by and for children

Delegated act on terms and conditions for CSIRTs

- Specifies the terms and conditions for applying the cybersecurity-related grounds in relation to delaying the dissemination of notifications
- Such a decision to delay may be taken in three circumstances:
  - in the light of an evaluation of the nature of the notified information;
  - if the CSIRT receiving the notification is unable to ensure the confidentiality of such information;
  - if the single reporting platform has been compromised or is temporarily not operational.
- link

CRA implementation tentative timelines

https://www.youtube.com/watch?v=QRLWcU_Yx18

CABs

- Regulation 2025/2162 the accreditation of conformity assessment bodies
- Here are the EUCC accredited (and where relevant authorised) CABs
- Accreditation of conformity assessment bodies

2025/2162 28.10.2025

COMMISSION IMPLEMENTING REGULATION (EU) 2025/2162

of 27 October 2025

laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and the Council as regards the accreditation of conformity assessment bodies performing the assessment of qualified trust service providers and the qualified trust services they provide, the conformity assessment report and the conformity assessment scheme

THE EUROPEAN COMMISSION,

Having regard to the Treaty on the Functioning of the European Union,

Having regard to Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC ([1]), and in particular Article 20(4) thereof,

Search results (21)

NOTIFICATION STATUS Active

LEGISLATION Regulation (EU) 2024/482 - European Common Criteria-based cybersecurity certific...

Body type	Body Name	Country
ITSEF 3083	SRC Security Research & Consulting GmbH	Germany
ITSEF 3101	secuvera GmbH	Germany
CB 3087	Bundesamt für Sicherheit in der Informationstechnik, EUCC Zertifizierungsstelle	Germany
ITSEF 3085	TÜV Informationstechnik GmbH	Germany
ITSEF 3084	atsec information security GmbH	Germany
ITSEF 3089	atsec information security AB	Sweden
CB 3114	Agenzia per la Cybersicurezza Nazionale - Organismo di Certificazione della Sicurezza Informatica	Italy
ITSEF 3106	Deutsche Telekom Security GmbH, Prüfstelle IT-Sicherheit	Germany
CB 3122	Certifikačný orgán NBÚ	Slovakia
CB 3095	DEKRA TESTING AND CERTIFICATION S.A.U.	Spain
CB 3096	LGAI Technological Center, S.A. (Applus+)	Spain
ITSEF 3097	Commissariat à l'énergie atomique et aux énergies alternatives	France
ITSEF 3096	LGAI Technological Center, S.A. (Applus+)	Spain
ITSEF 3095	DEKRA TESTING AND CERTIFICATION S.A.U.	Spain
ITSEF 3100	SGS Brightsight B.V.	Netherlands
ITSEF 3088	SERMA SAFETY AND SECURITY	France
CB 3090	Agence nationale de la sécurité des systèmes d'information	France
CB 3089	atsec information security AB	Sweden
CB 3110	TrustCB B.V.	Netherlands
ITSEF 3118	Red Alert Labs SAS	France
ITSEF 3124	Keysight Technologies Netherlands Riscure B.V.	Netherlands

NBs

- You can find all available NBs in Europe here:

Search results (1527)

Showing results 1 - 100

NOTIFICATION STATUS Active

Items per page: 100 CSV

Body type	Body name	Country
NB 0197	TÜV Rheinland LGA Products GmbH	Germany
NB 0123	TÜV SÜD Product Service GmbH	Germany
NB 2797	BSI Group The Netherlands B.V.	Netherlands
NB 0537	Eurofins Electric & Electronics Finland Oy	Finland
NB 1325	AS Kiwa Latvia	Latvia
NB 0649	SGS Belgium NV - Division SGS CEBEC	Belgium
NB 0493	CENTEXBEL (WETENSCHAPPELIJK EN TECHNISCH CENTRUM VAN DE BELGISCHE TEXTIELNIJVERHEID - DIVISIE GENT)	Belgium
NB 0080	INSTITUT NATIONAL DE L'ENVIRONNEMENT INDUSTRIEL ET DES RISQUES	France
NB 1787	Kaalukoda A.A. OÜ	Estonia

- You can find all available NBs for CRA in Europe here:

Search results (0)

NOTIFICATION STATUS Active

LEGISLATION Regulation (EU) 2024/2847 on horizontal cybersecurity requirements for products ...

CSV

Body type	Body name	Country
	No data	

MSAs & AdCos

Market Surveillance Authorities

Refine list of Market Surveillance Authorities using search criteria below (by entering appropriate keywords)

Search options

Country
All countries

Postal code

City/Area

Street

Authority name

Authority number

Directive / Regulation
1 2024/2847/EU - Cyber Resil…

Search results (4)

DIRECTIVE / REGULATION 2024/2847/EU - Cyber Resilience Act (CRA) Regulation ⊗

Authority	Street	Postal code	City
Digital Security Authority	Andrea Chaliou	2408	Nicosia
Consumer Rights Protection Centre of Latvia	Brivibas street	LV-1010	Riga
National Security Authority	Budatínska	85106	Bratislava
Bundesamt für Sicherheit in der Informationstechnik (BSI)	Godesberger Allee	53175	Bonn

European cooperation on market surveillance takes place through groups of market surveillance authorities, called Administrative Cooperation Groups (AdCos).

https://webgate.ec.europa.eu/single-market-compliance-space/market-surveillance/ms-authorities?filter=legislationId:9021
https://single-market-economy.ec.europa.eu/single-market/goods/building-blocks/market-surveillance/organisation/adcos_en

Have your say

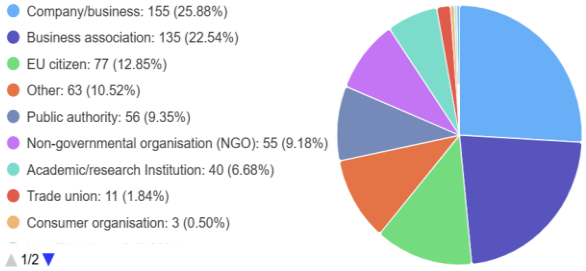
Public consultation to gather your views on revising the EU Standardisation Regulation

- EU launched a public consultation to gather your views on revising the EU Standardisation Regulation.
- This is your opportunity to contribute to a strategic, future-proof approach to standardisation in Europe
- We worked on a submission at the level of LF
  - LFEU was the submitter
  - Supporting papers from OpenSSF, SPDX, JDFP

Total of valid feedback instances received: 599

The number feedback instances shown includes only the valid ones, respecting the feedback rules. The data is regularly updated.

By category of respondent



Public Consultation on European Open Digital Ecosystem Strategy

- https://ec.europa.eu/info/law/better-regulation/have-your-say/initiatives/16213-European-Open-Digital-Ecosystems_en
- The European Open Digital Ecosystem Strategy will set out:
  - a strategic approach to the open source sector in the EU that addresses the importance of open source as a crucial contribution to EU technological sovereignty, security and competitiveness
  - a strategic and operational framework to strengthen the use, development and reuse of open digital assets within the Commission, building on the results achieved under the 2020-2023 Commission Open Source Software Strategy.

RED DA Repeal

- https://ec.europa.eu/info/law/better-regulation/have-your-say/initiatives/14766-Cybersecurity-repeal-of-Delegated-Regulation-supplementing-the-Radio-Equipment-Directive_en
- Deadline tomorrow, 7 January
- This initiative aims to repeal Delegated Regulation 2022/30 on cybersecurity once the Cyber Resilience Act becomes fully applicable on 11 December 2027.
- This will avoid any overlaps between the essential requirements of the Radio Equipment Directive that relate to cybersecurity and those of the Cyber Resilience Act. It will also ensure legal certainty.

ENISA’s calls for feedback

- OpenSSF has submitted a very general feedback for their **Survey on SBOM State of the Art**
- **Advancing Software Supply Chain Security together**
  - draft report
  - You may provide your feedback by **23 January 2026 at 23:59 CET** by taking part in the survey
- **ENISA Technical Advisory for Secure Use of Package Managers**
  - draft document
  - You may take part in the consultation for the Technical Advisory **by 23 January 2026, 23:59 CET** through the following link

AOB

Cyberstand Funding: SME Perspective on CRA Standards

- There is a new call for experts focusing on the review of standards from an SME perspective
- The EU-funded project **Cyberstand.eu** has launched a dedicated funding round to support expert **reviews of draft European standards** developed in support of the CRA.
- This call focuses specifically on the **SME perspective**, helping identify where standards could be clarified or adjusted to improve proportionality, feasibility, and avoid unnecessary burdens.

📌 Apply by 16 January:
👉 10th Specific Service Procedure - SME Perspective | Cyberstand

ECCC publishes new call for proposals under Digital Europe Programme

- https://cybersecurity-centre.europa.eu/news/eccc-publishes-new-call-proposals-under-digital-europe-programme-2025-10-22_en
- The call Cyber 09 focuses on critical areas of cybersecurity deployment and covers the following topics:
  - Cybersecure tools, technologies and services relying on AI
  - Uptake of innovative cybersecurity solutions for SMEs
  - Coordinated preparedness testing and other preparedness actions
  - Regional Cable Hubs

Revised NIST SSDP

- V1.2
- https://csrc.nist.gov/pubs/sp/800/218/r1/ipd
- *"Future work may expand on this publication and potentially cover topics such as how the SSDF may apply to and vary for particular software development methodologies and associated practices like DevOps, how an organization can transition from their current software development practices to also incorporating the SSDF practices, and **how the SSDF could be applied in the context of open-source software**. Future work will likely take the form of use cases so that the insights will be more readily applicable to specific types of development environments, and it will likely include collaboration with the open-source community and other groups and organizations."*

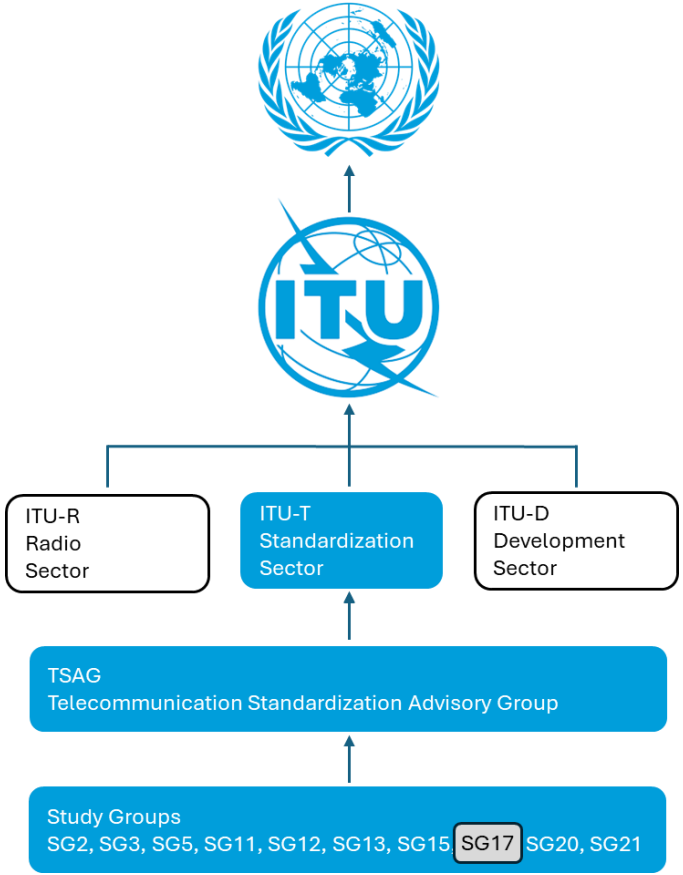
NIST Special Publication 800
NIST SP 800-218r1 ipd

Secure Software Development Framework (SSDF) Version 1.2

Recommendations for Mitigating the Risk of Software Vulnerabilities

ITU-T SG17

- Madalin represented OpenSSF at the next ITU-T SG17 meeting in Geneva
- In alignment with our intention to increase our partnership database
- We want to establish a partnership with them that could allow us also to contribute wherever our help is needed
- Madalin met with Deputy Director of TSB, and Counsellor for ITU-T SG17
- We'll continue the discussions



Thank you very much

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Back-up slides

CRA Standardization request

EUROPEAN COMMISSION

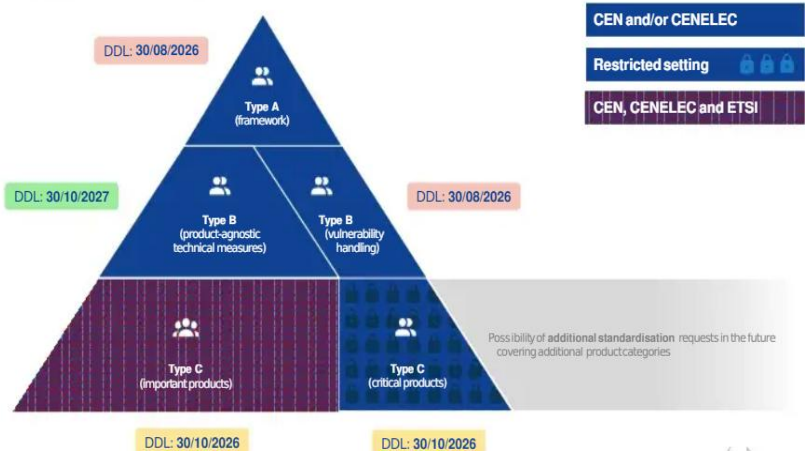
Brussels, 3.2.2025
C(2025) 618 final

COMMISSION IMPLEMENTING DECISION

of 3.2.2025

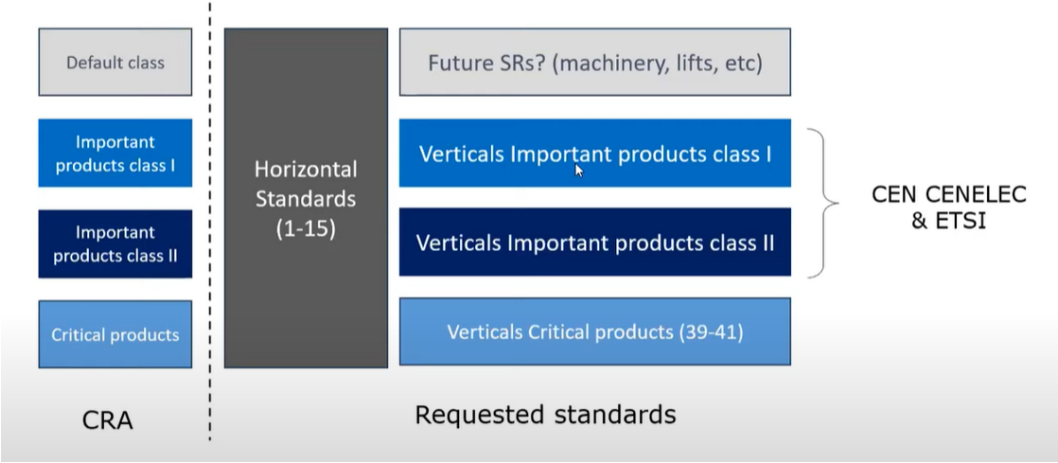
on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)

https://ec.europa.eu/transparency/documents-register/detail?ref=C(2025)618&lang=en
https://cyberstand.eu/sites/default/files/2025-02/Filipe%20Slides%20CRA_implementation_Feb-2025.pdf



Horizontal standards (1-15)	Vertical standards (16-41)
• Risk-based approach (CRA Annex I) • Essential Requirements (CRA Annex I part 1) • Vulnerability Handling (CRA Annex I part 2)	• Important products class 1 (CRA Annex III) • Important products class 2 (CRA Annex III) • Critical products (CRA Annex IV)

CRA Standardization request

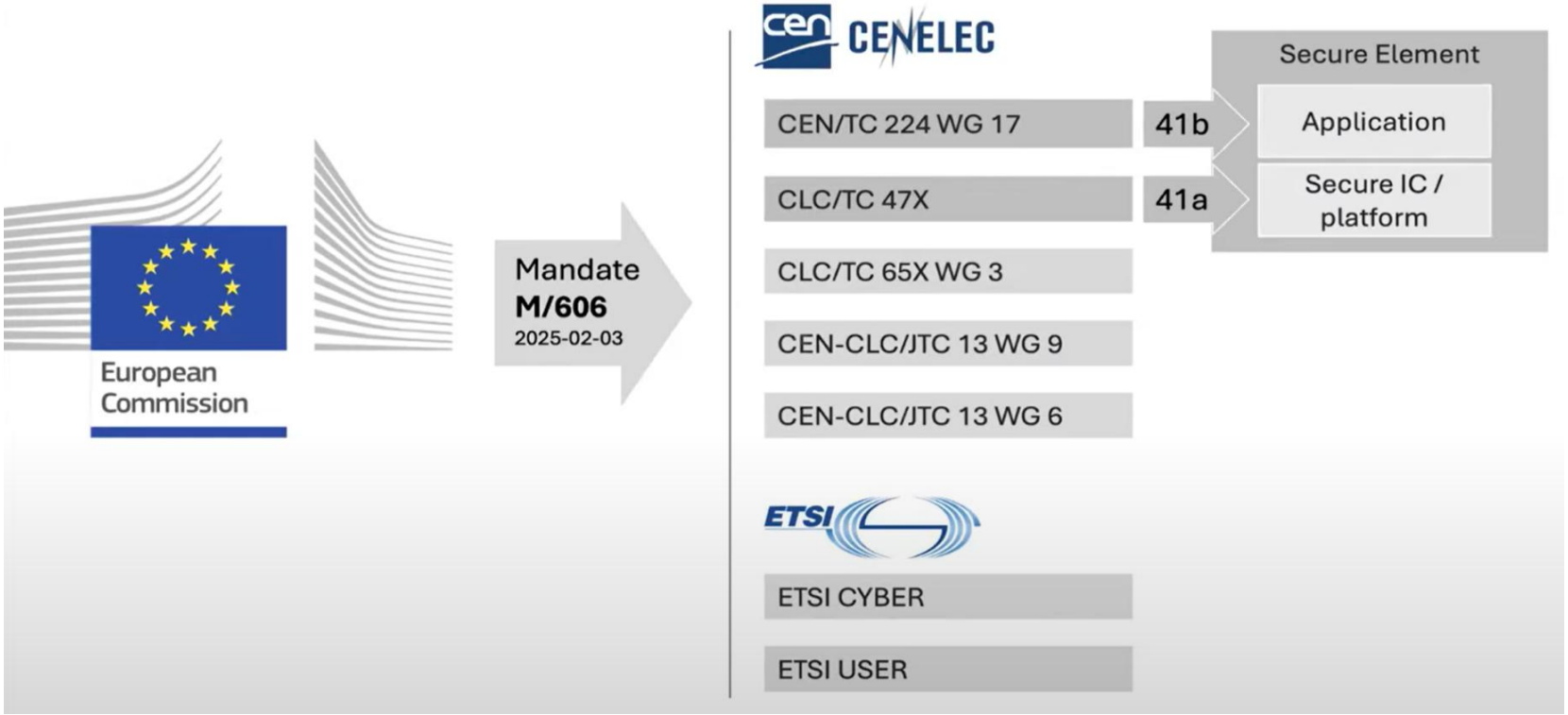


41 topics

3 ‘types’ of deliverables:

Category “A”: horizontal framework	Category “B”: product-agnostic technical measures & vulnerability handling	Category “C”: Important and critical products CRA Standardization Request 9 April 2025 36
• Only CEN and CENELEC • Topic #1 (JTC 13 WG9) • deadline 2026-08-30	• Only CEN and CENELEC • Topic #2-15 (JTC 13 WG9) • Deadline 2027-10-30 (except for line 15 - vulnerability handling - 2026-08-30)	• Topic #16-38: CEN, CENELEC and ETSI • deadline 2026-10-30 • Topic #39-41:CEN and CENELEC • Critical products

CRA Standardization request



https://www.youtube.com/watch?v=_C9HGqBT6qw

A section of the CEN, CENELEC and ETSI WP

Version: V1
Date: 2025-04-02

CEN, CENELEC and ETSI Work Programme
M/604- Cyber Resilience Act

M/606	Technical Committee(s)		M/606 - Planning for standard development						
Topics M606 - Annex I	TC ref.	TC title	In collaboration with	Work Item	Standard reference	Standard title	Last realized stage	Deadline for adoption	Comment
Line 1: European standard(s) on designing, developing and producing products with digital elements in such a way that they ensure an appropriate level of cybersecurity based on the risks									
1	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013089	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements Principles for cyber resilience	10.99 - NWI - New Work Item adopted	2026/08/30	
Lines 2-14 - European standard(s) CRA essential requirements									
2 to 14	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013091	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements – Generic Security Requirements	10.99 - NWI - New Work Item adopted	2027/10/30	
Line 15: European standard(s) on vulnerability handling for products with digital elements									
15	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013090	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements – Vulnerability handling	10.99 - NWI - New Work Item adopted	2026/08/30	
Line 16: European standard(s) on essential cybersecurity requirements for identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers									
16	CEN/TC 224 WG 17	Personal identification and related personal devices with secure element, systems, operations and privacy in a multi sectorial environment	CEN/TC 224 WG 17 (including expertise from WG 18,19 and 20) TC ESI	002242XX	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers : criteria to fulfill with the essential requirements from regulation 2024/2487 (CRA)	TC decision taken	2026/10/30	
Line 17: European standard(s) on essential cybersecurity requirements for standalone and embedded browsers									
17a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 617-1*	European standard(s) on essential cybersecurity requirements for embedded browsers	PWI - Proposed Work Item created	2026/10/30	
17b	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 617-2*	European standard(s) on essential cybersecurity requirements for standalone browsers	PWI - Proposed Work Item created	2026/10/30	
Line 18: European standard(s) on essential cybersecurity requirements for password managers									
18	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 618*	European standard(s) on essential cybersecurity requirements for password managers	PWI - Proposed Work Item created	2026/10/30	
Line 19: European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software									
19	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 619*	European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software	PWI - Proposed Work Item created	2026/10/30	
Line 20: European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)									
20a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9 CLC/TC 65X WG3 mode 2	*(Will be be defined after the adoption of the Work Item)*	*EN 304 620*	European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)	PWI - Proposed Work Item created	2026/10/30	
20b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	ETSI TC Cyber EUSR Mode 2	81652	*EN 62443-5-XX (Will be be defined after the activation of the Work Item)*	Security Profile for products with digital elements with the function of virtual private network (VPN)	00.60 - PWI - Preliminary Work Item created	2026/10/30	
Line 21: European standard(s) on essential cybersecurity requirements for network management systems									
21a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9 CLC/TC 65X WG3 mode 2	*(Will be be defined after the adoption of the Work Item)*	*EN 304 621*	European standard(s) on essential cybersecurity requirements for network management systems	PWI - Proposed Work Item created	2026/10/30	
21b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	ETSI TC Cyber EUSR Mode 2	81650	*EN 62443-5-XX (Will be be defined after the activation of the Work Item)*	Security Profile for network management systems (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30	

Not complete

https://www.cencenelec.eu/media/CEN-CENELEC/News/Newsletters/2025/m_606_work_programme_final.pdf

CEN/CENELEC Work Programme

Project Team 1	Project team 2	Project team 3

• **Cybersecurity requirements for products with digital elements – Principles for cyber resilience**
• WI number – JT013089
• CRA requirement Annex I, Part I, 1
• M/606 item 1, 30/08/2026
• Does not (directly) provide a presumption of conformity.
• Addressing the process activities for security risk management during the total product life cycle.
• Activities are described as:
  • Expected inputs
  • Requirement
  • Expected outputs
  • Assessment criteria
• As a horizontal framework standard, it will not mandate any specific methodologies.
	• **Cybersecurity requirements for products with digital elements – Generic security requirements**
	• WI number : JT013091
	• CRA requirement Annex I, Part I, 2
	• M/606 items 2-14, 30/10/2027
	• Does not provide a presumption of conformity.
	• Addressing the essential product requirements.
	• Provides a library of security controls with their objectives and more technical assessment criteria.
	• Provides a mapping of the essential requirements to these security controls.
	• Builds upon the EN 18031:2024 series, augmented with additional security controls.
		• **Cybersecurity requirements for products with digital elements – Vulnerability handling**
		• WI number : JT013090
		• CRA requirement Annex I, Part II
		• M/606 item 15, 30/08/2026
		• The only horizontal standard of the three that hopefully might be suited for citation to provide a partial presumption of conformity.
		• Addressing the process activities for vulnerability handling.
		• Perceived as a horizontal standard that the verticals should be able to normatively reference with no or minimal adoptions.
		• Strong normative dependency on the SOTA standards EN ISO/IEC 30111 and 29147.

CEN/CENELEC JTC 13 WG9 Work Programme

Project 1

High level process **activities** to address the Total Product Life Cycle, defining:

- Goal that needs to be achieved
- Mandatory and optional inputs
- Minimum expected outcomes

Process activities such as security monitoring, risk assessment, verification, validation and release

Project 3

More detailed process **activities** (with assessment criteria fit for a presumption of conformity) to address the vulnerability management requirements

During risk assessment the appropriate security controls and their appropriate level can be selected to ensure risks are mitigated to an acceptable level

Risk assessment

Product requirements

Project 2

A mapping of the essential product requirements to a list of appropriate **security controls** at various levels

(controls have their own scale/levels to achieve the goal of the security control)

During the elicit requirements activity the deliverables from project 2 can be used to determine and select the appropriate security controls that should be implemented into the product to fulfil on a risk-based manor the essential requirements

ETSI Work Programme

18 WIs, Work in progress, displaying 1 to 18				Displays
Work item number	Version	Current status	Next status	Rapporteur name
CYBER EUSR				
DEN/CYBER-EUS-0010 (EN 304 622) CRA SIEM systemsTopic # 22 Part 1/2	0.0.4	Final deliverable registered for formal adoption (2025-11-10)	Final deliverable voting initiated	Toikka Santeri
DEN/CYBER-EUS-0011 (EN 304 631) CRA Smart home assistants Topic # 31 full	0.0.3	Early draft (2025-11-05)	Stable draft	Mitterweger Kilian
DEN/CYBER-EUS-0012 (EN 304 626) CRA operating systemsTopic # 26 Part 1/N	0.0.9	Stable draft (2025-11-03)	Mature draft	Black Aeva
DEN/CYBER-EUS-0013 (EN 304 627) CRA routers, modems, and switches Topic # 27 Part 1/2	0.0.8	Stable draft (2025-10-25)	Mature draft	Banelli Bruno
DEN/CYBER-EUS-0014 (EN 304 632) CRA Smart home security products Topic # 32 full	0.0.3	Early draft (2025-11-05)	Stable draft	Mitterweger Kilian
DEN/CYBER-EUS-0015 (EN 304 624) CRA PKI and digital certificate issuance software - Topic #24	0.0.5	Early draft (2025-10-30)	Stable draft	Haddad Sammy
DEN/CYBER-EUS-0016 (EN 304 635) Essential cybersec reqts for hypervisors and container runtime systems	0.0.8	Stable draft (2025-11-09)	Mature draft	Hajj Mohamad
DEN/CYBER-EUS-0017 (EN 304 625) Essential cybersec reqts for physical and virtual network interfaces	0.0.9	Stable draft (2025-11-05)	Mature draft	Aurora Valerie
DEN/CYBER-EUS-0018 (EN 304 619) CRA antivirus software Topic # 19 full	0.0.7	Stable draft (2025-10-31)	Mature draft	Alemany Pol
DEN/CYBER-EUS-0019 (EN 304 642) Cybersecurity reqts for Network functions of Telecoms systems	0.0.4	Early draft (2025-11-05)	Stable draft	Sahlin Bengt
DEN/CYBER-EUS-0020 (EN 304 636) Essential cybersec reqts for firewalls, intrusion detection and prevention systems	0.0.6	Final deliverable registered for formal adoption (2025-11-10)	Final deliverable voting initiated	Samardzic Damir
DEN/CYBER-EUS-003 (EN 304 634) CRA Personal wearables Topic # 34 full scope	0.0.2	Early draft (2025-09-30)	Stable draft	Pratone Davide
DEN/CYBER-EUS-004 (EN 304 633) CRA Internet connected toys Topic # 33 full scope	0.0.3	Early draft (2025-11-05)	Stable draft	Meister Gisela
DEN/CYBER-EUS-005 (EN 304 620) CRA VPNs Topic # 20 Part 1/2	0.0.13	Early draft (2025-11-02)	Stable draft	Braun Aki
DEN/CYBER-EUS-006 (EN 304 617) CRA essential cyber reqts for browsers Topic # 17	0.0.6	Stable draft (2025-11-03)	Mature draft	Thompson-Yvetot Daniel
DEN/CYBER-EUS-007 (EN 304 618) CRA password managers Topic # 18 full	0.0.3	Final deliverable registered for formal (2025-11-10)	Final deliverable voting initiated	Thompson-Yvetot Daniel
DEN/CYBER-EUS-008 (EN 304 623) CRA boot managersTopic # 23 Full	0.0.8	Early draft (2025-11-06)	Stable draft	Horchert Christian
DEN/CYBER-EUS-009 (EN 304 621) CRA Network Management Topic # 21	0.0.6	Early draft (2025-10-22)	Stable draft	Toikka Santeri

Key information

- https://portal.etsi.org/home.aspx
- All the works are under the control of TC CYBER WG EUSR https://portal.etsi.org/tb.aspx?tbid=919&SubTB=919#/
- The work programme and the meeting schedule can be found navigating on that page
  - Very intense meeting schedule
  - They have monthly joint meetings with CEN and CENELEC
  - They have weekly general syncs
- Their Forge https://forge.etsi.org/rep/cyber/stan4cr2
  - Only 10 standards (among 18) are developed using markdown
  - The links are also displayed on the WI page
- Links for Public Consultation on ETSI standards
  - https://docbox.etsi.org/CYBER/EUSR/Open
  - https://labs.etsi.org/rep/stan4cra/